

Agentic Security

Machine-Speed Response and the Fog of Cyber War

Operations

Your Host



BESPIN GLOBAL

MATT FRANZ

leads Bespin Global Security Products & Services

Over 25 Years in Cyber in Engineering,
Operations & Product Development

US Army Reserve NOC &
Intel Analyst (SIGINT & All
Source) in 1990's

10 Years of Production
Cloud Experience
(Mostly AWS)

B.A. in English & History
avid reader of Military
History & Strategy

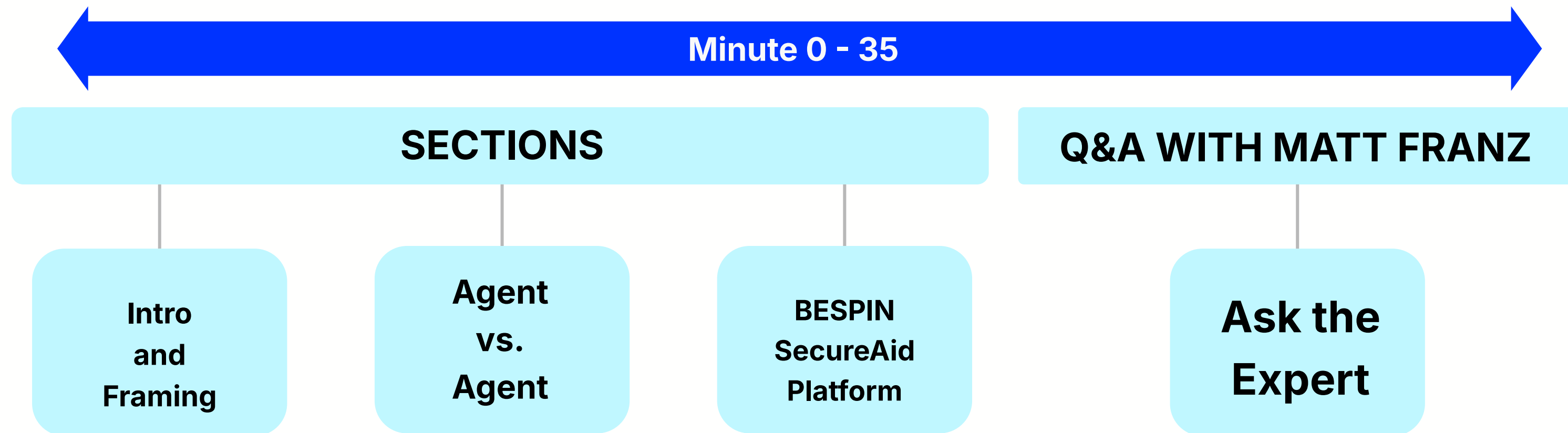
held senior technical & leadership roles at



Webinar Goals & Agenda



- ✓ Put Offensive & Defensive AI in Context (No Hype/No FUD)
- ✓ Assess Agentic Security Operations through the lens of Military Science
- ✓ See how to put these principles into practice at Bespin with SecureAid



PART 1: OVERVIEW



SitRep 2026: *this VUCA*

A challenging decade for global security teams

(even if you leave out the big breaches and vulnerabilities)

Decade

Ukraine Drone, Cyber,
Cognitive Warfare (2022-)

ZIRP Tech Bubble/ Bust and
continuous M&A (2021-)

Generative AI
(2023-)

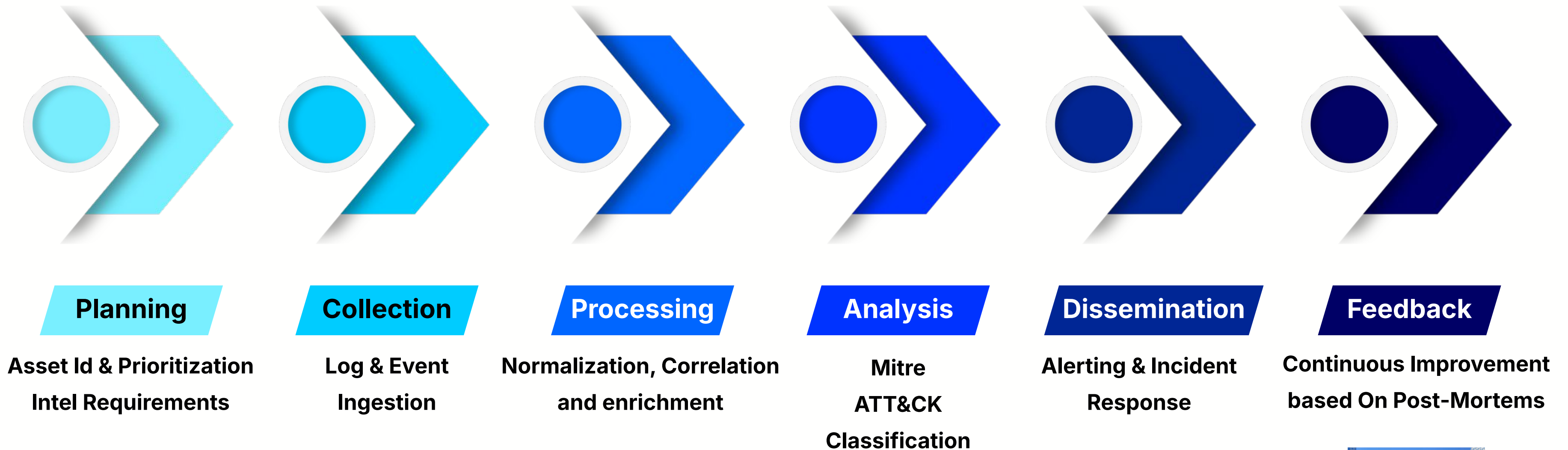
A Global Pandemic with
Supply Chain Disruptions
(2020-2022/2025-)

U.S. and Global
Instability (2025-)



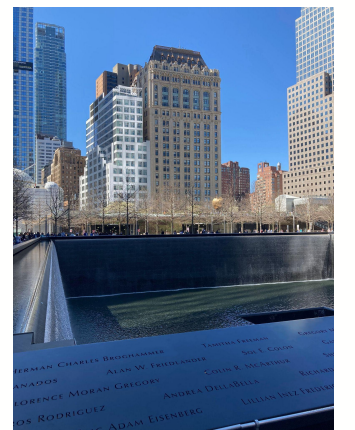
Security Ops as an Intel Cycle (Pre-AI)

the Intel Cycle (tactical, operational, or strategic)



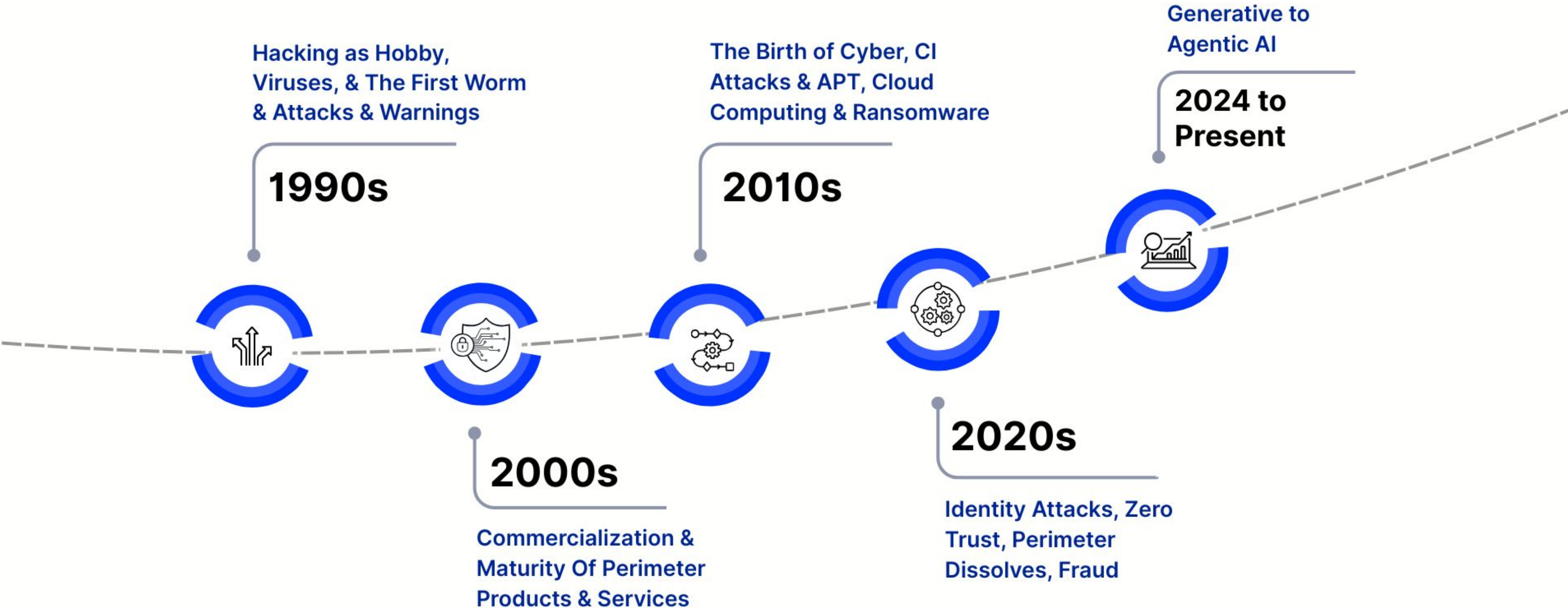
BUT... Remember famous Intel failures!

Pearl Harbor, The Ardennes 1944, 9/11 – *Your SOC?*



30 Years of Computer Security

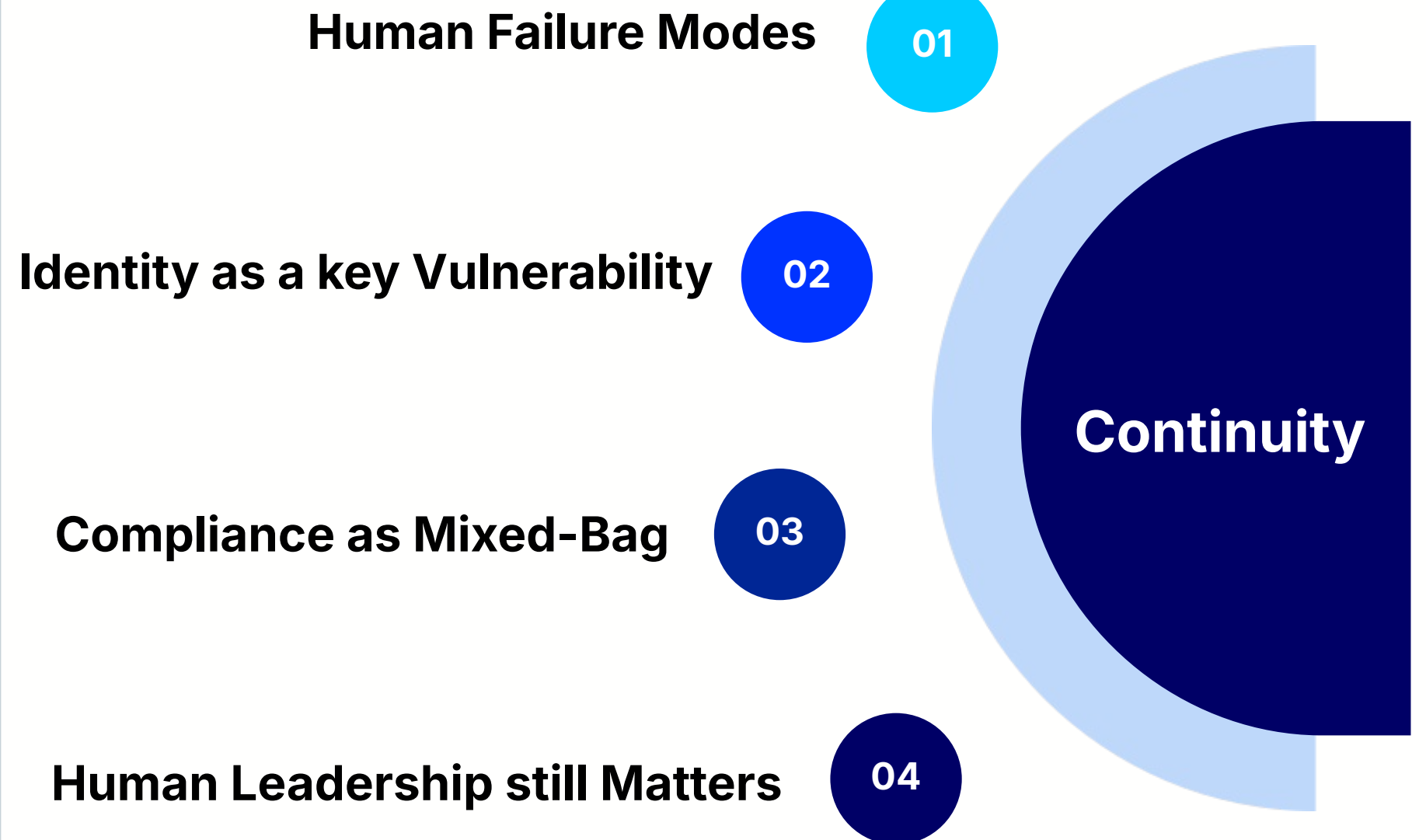
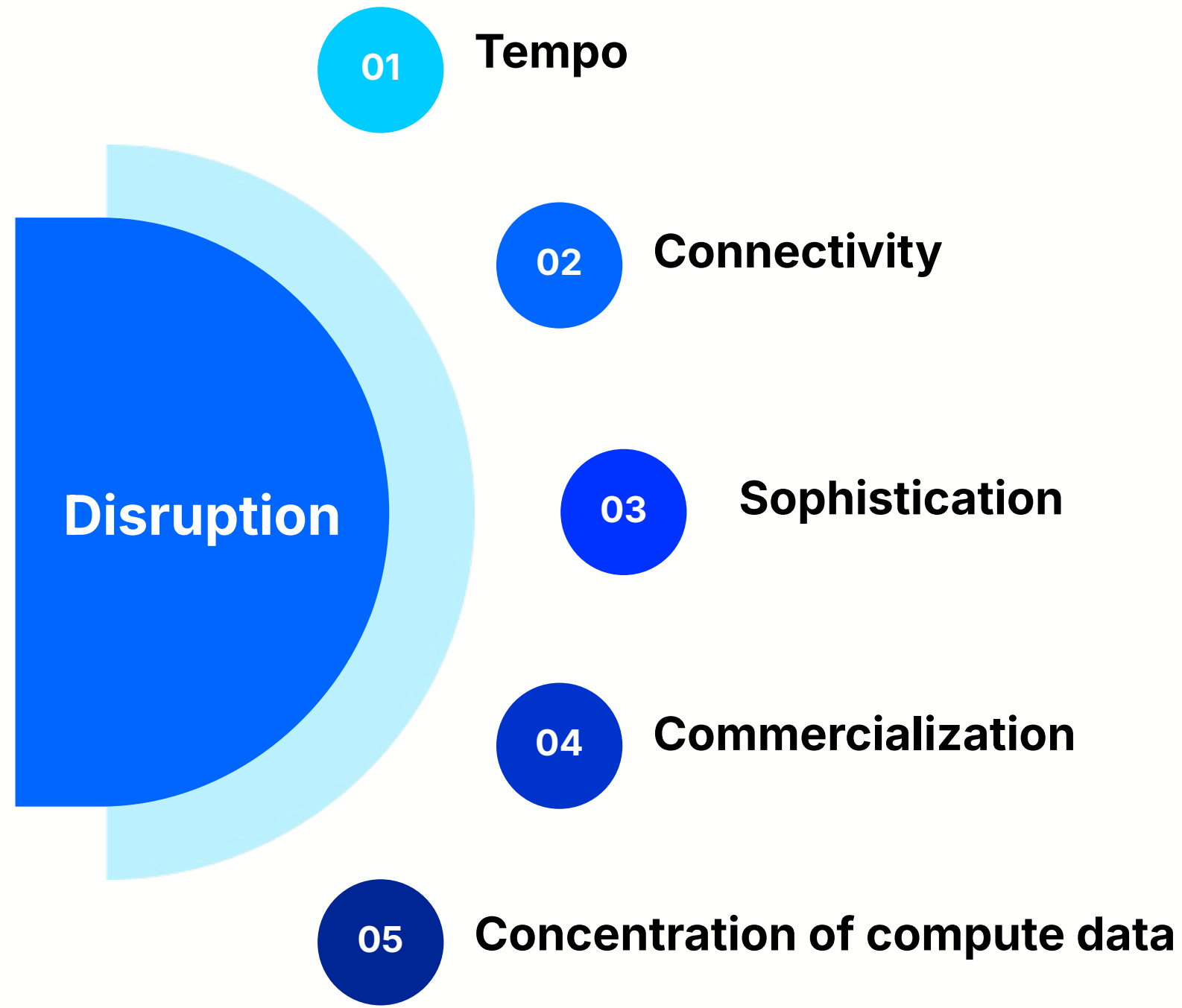
(before it was Cyber)

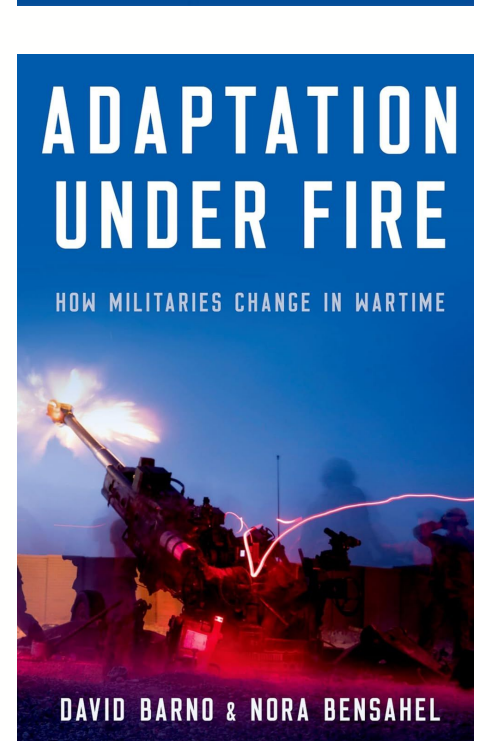
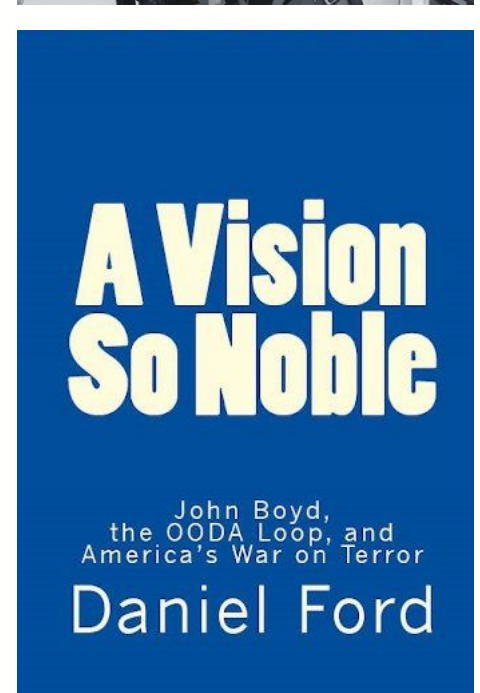
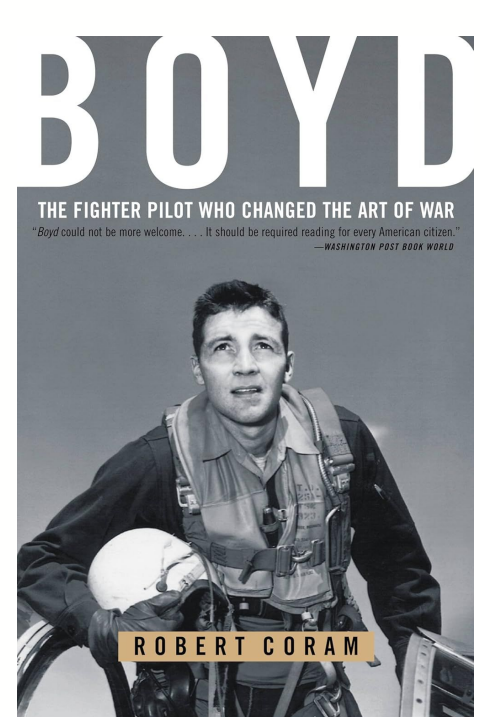


30 Years of Computer

(What has changed? What remains the same?)

Security





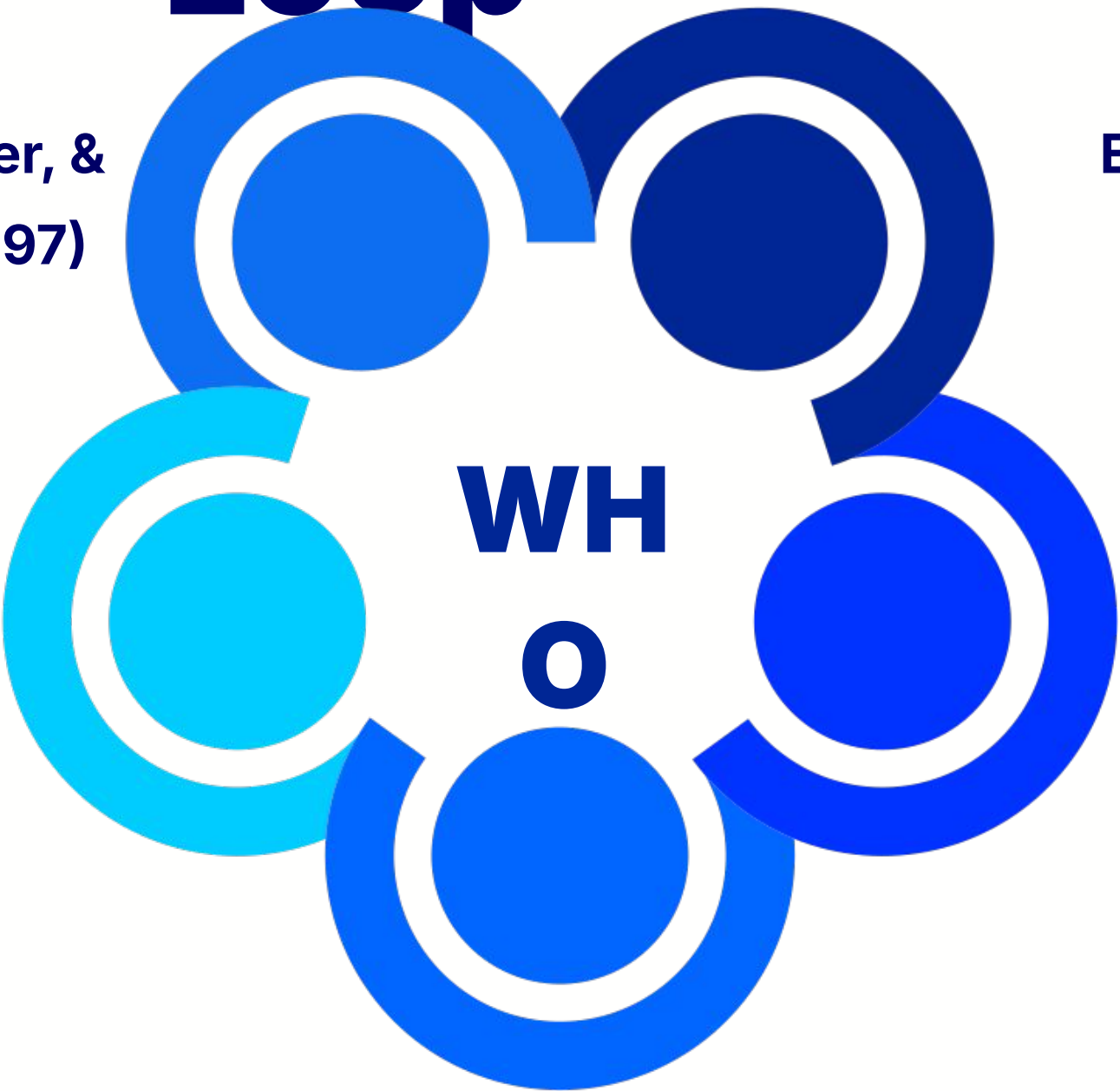
John Boyd & The OODA Loop

Fighter Pilot, Trainer, &
Engineer (1927-1997)

Energy-Maneuverability
Theory

Built upon Sun Tzu &
Karl von Clausewitz

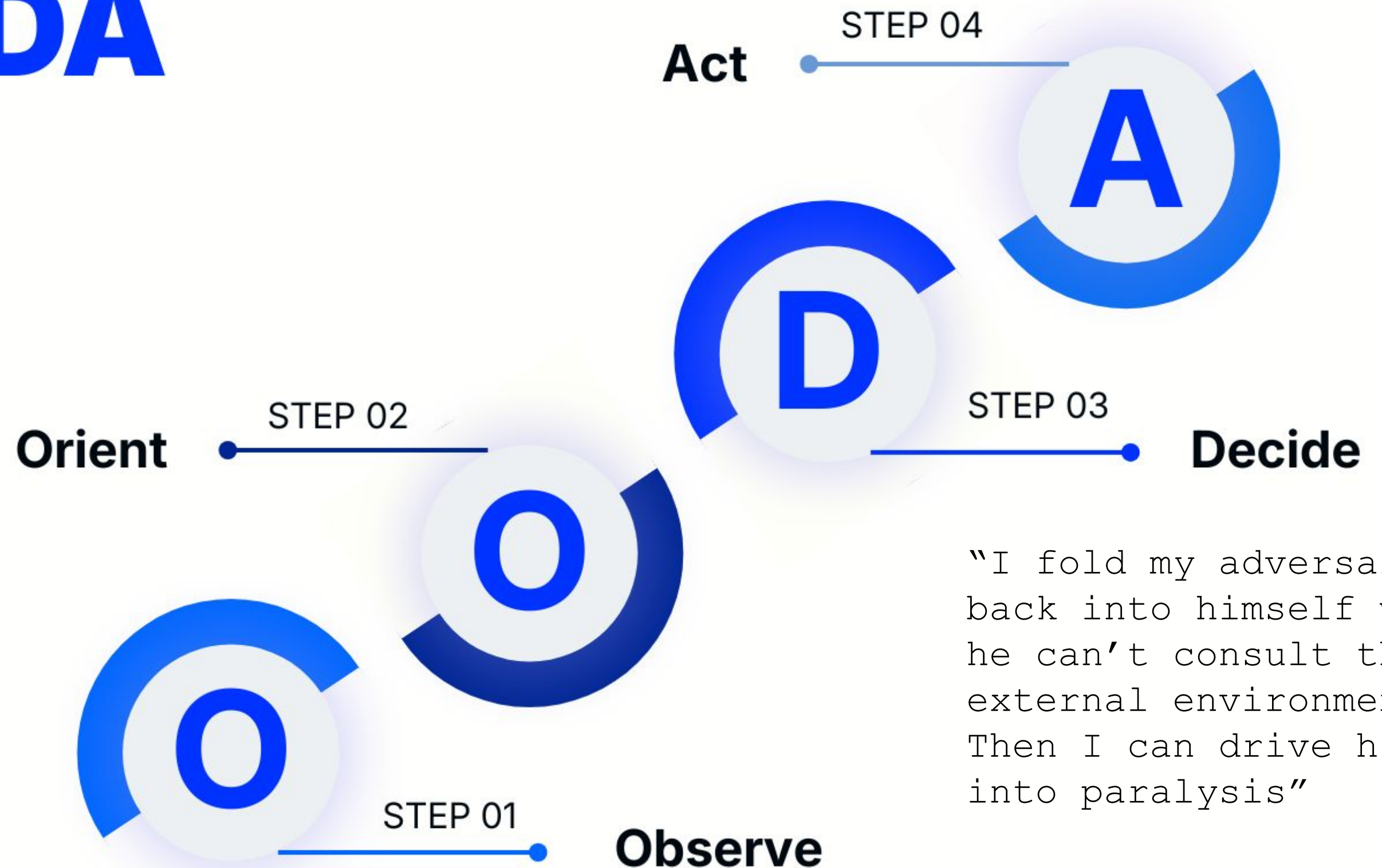
Shaped design of 20th
Fighters (F-15/16/18)



Organizational Agitator &
Disruptor at the Pentagon

The OODA Loop

A repetitive non-linear cycle where the goal is to iterate faster than the adversary



"I fold my adversary back into himself where he can't consult the external environment... Then I can drive him into paralysis"

SecOps Lessons: Increase tempo, rapid orientation, reduce decision-making, remediate quickly!

Got Clausewitz?

- Prussian General who wrote On War based on his experience in over 30 battles during Napoleonic Era – learning from defeat and adversaries (Revolutionary Franc)
- Influenced The 20th Century Doctrine In The World Wars, including John Boyd
- True systems thinker who believed defenders actually had an advantage!

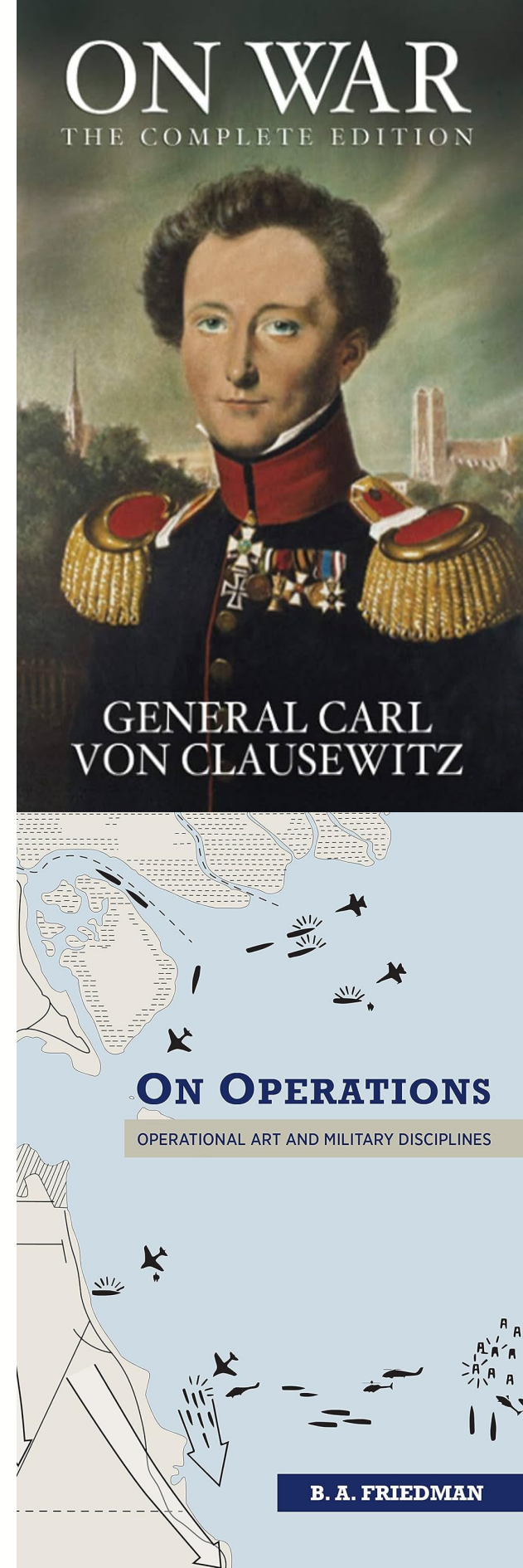
"The Enemy gets a vote!"



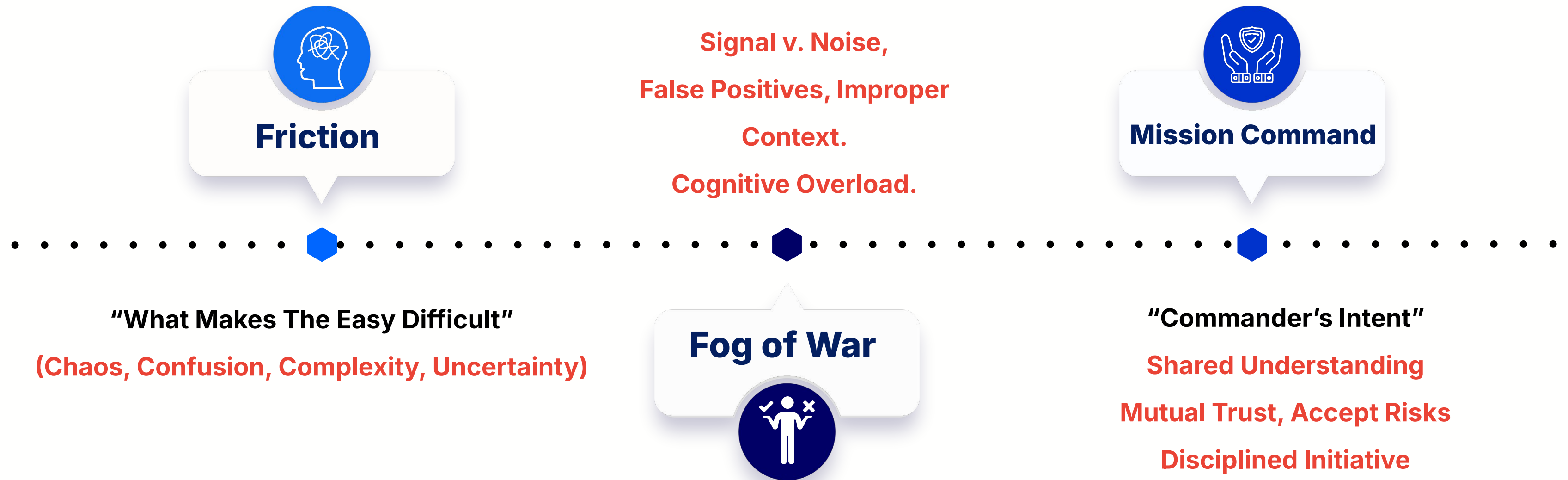
David J. Bianco
@DavidJBianco

You've heard of the Defender's Dillema: "Defenders have to get it right every time. Attackers only have to get it right once."

Did you know this is a lie?



Clausewitz: *as relevant as ever*



"AI amplifies human strengths and weaknesses at scale. Modernization experiments consistently show that humans, not machines, remain the limiting factor in machine-speed decision cycles. The challenge is not computational power but the need for soldiers who can interpret, prioritize, and choose."

PART 1 - Conclusion

01

Cybersecurity is now global & operating at a tempo where response must occur In **Minutes To Seconds** vs. **Days or Weeks!**

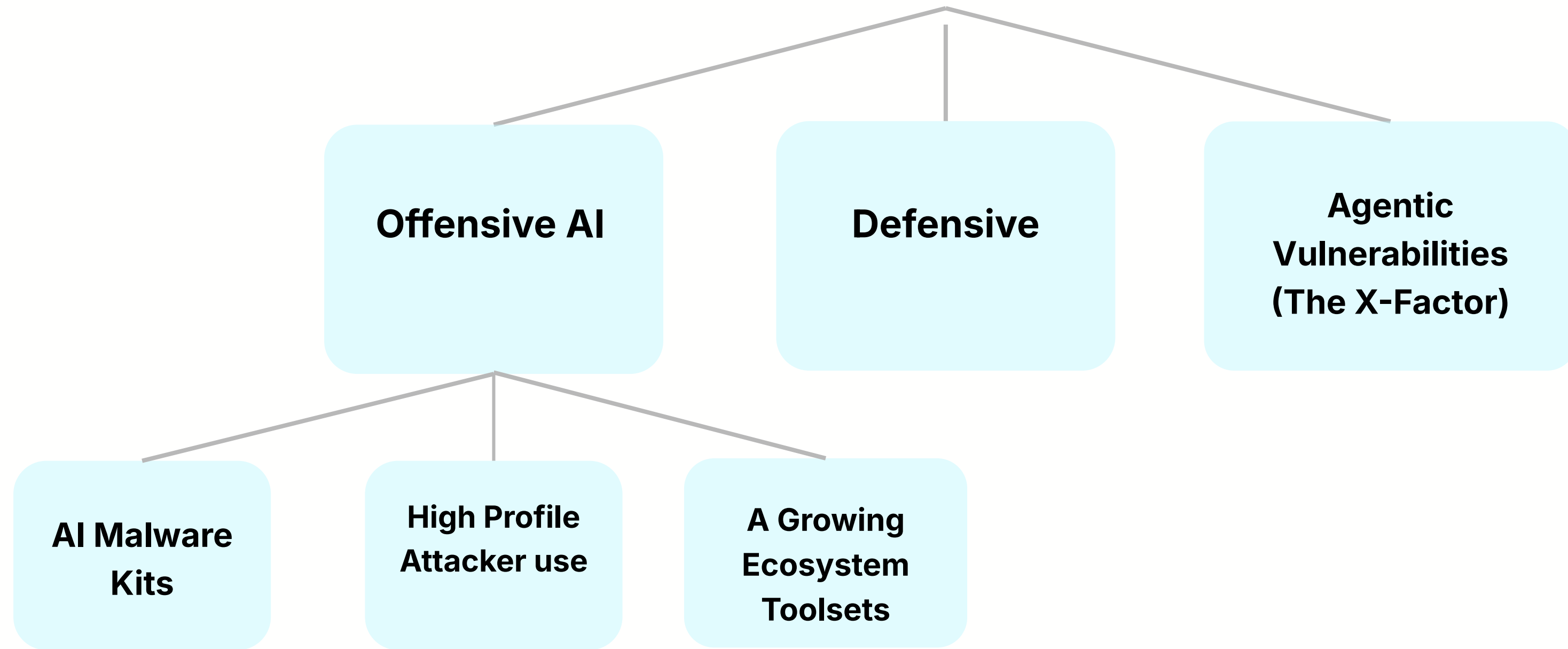
02

Concepts From Military Science (**from decades to centuries old**) help us frame problems & solutions faced by Security Teams, even in The "Age of AI"

03

We must to rethink/revamp Security Orgs as we **do more with less & faster** and delegate our Defenses To Agents

PART 2: AGENT vs. AGENT

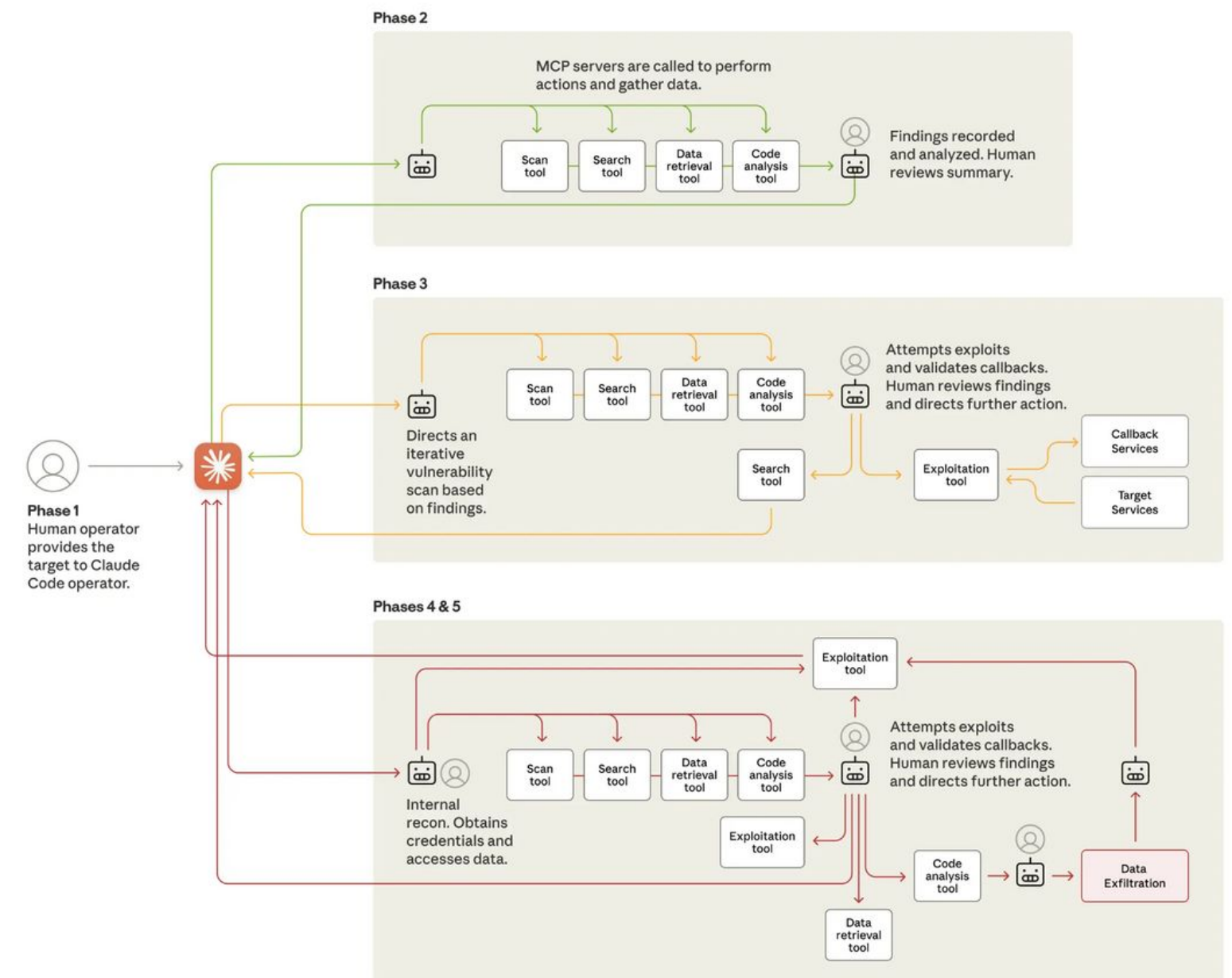


Crash of 2:45
(May 6, 2010)

Anthropic GTG-1002

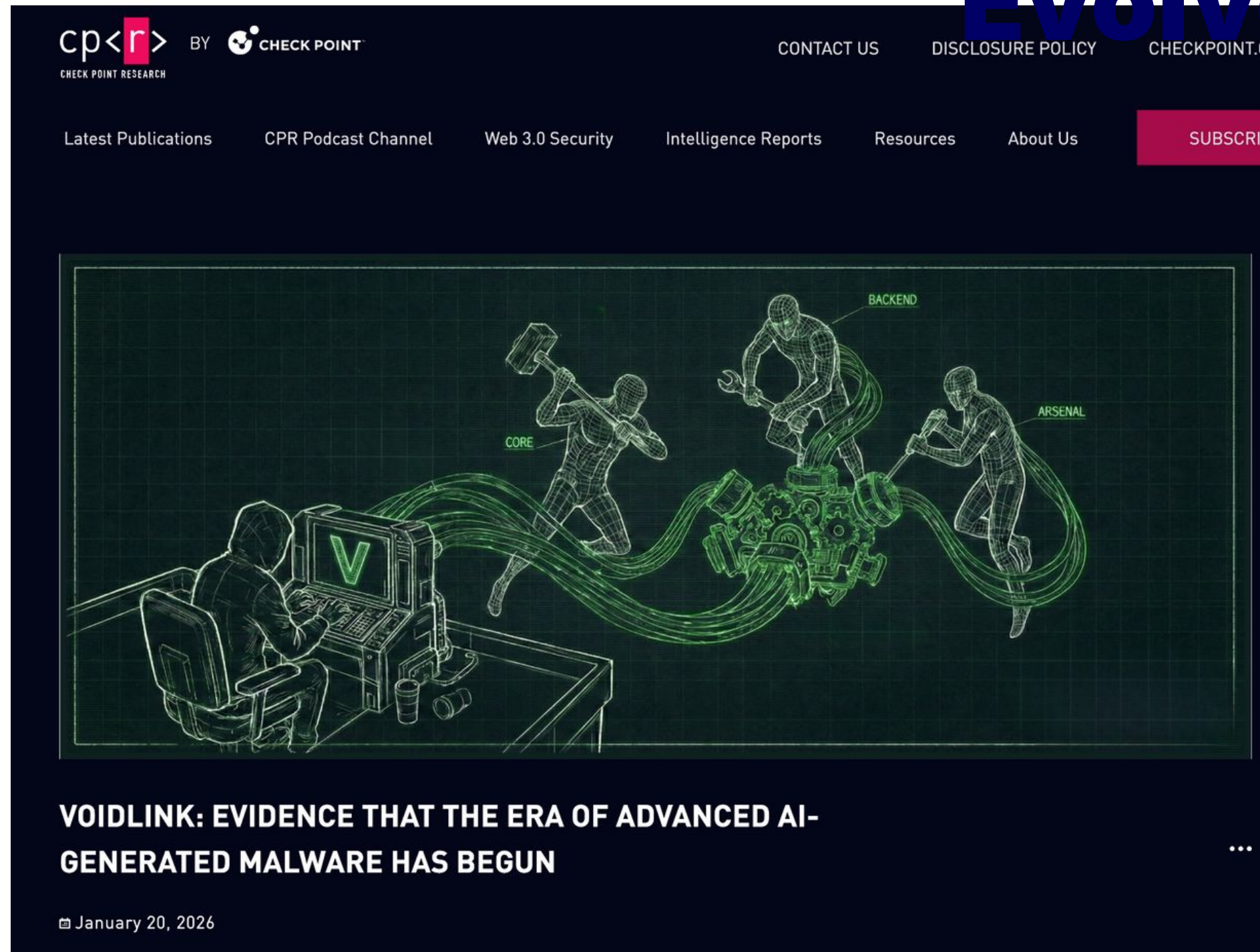
(September 2025)

- Anthropic Disclosed a State-Sponsored Espionage Campaign Using an **AI Coding Agent (Claude Code)** using MCP.
- High confidence attribution to **PRC** targeting 30 Organizations Across Tech, Finance, Chemical & Govt
- **Human-On-The-Loop Model**: Humans Issue High-Level Intent; The Agent Executes **80–90%** of the Intrusion Chain & Humans Intervene Mainly to Correct Errors/Hallucinations.



AI-Developed Malware

Evolves



✓ **June '23** - Worm GPT

✓ **2024** - WolfGPT & FraudGPT - primarily Phishing Related

✓ **March '24** - FunkSec AI RaaS Gang (GhostAlgeria)

✓ **March '24** - FunkSec AI RaaS Gang (GhostAlgeria)

✓ **Jan '26** - VoidLink uses Zig for Low level Linux exploit kit for cloud environments, implant developed in a week using "spec-driven development"

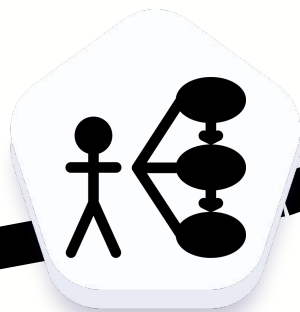
BESPIN GLOBAL

A Growing Offensive Ecosystem



AUTOgpt

Basic Wrappers For
ChatGPT & AutoGPT



2023



2024



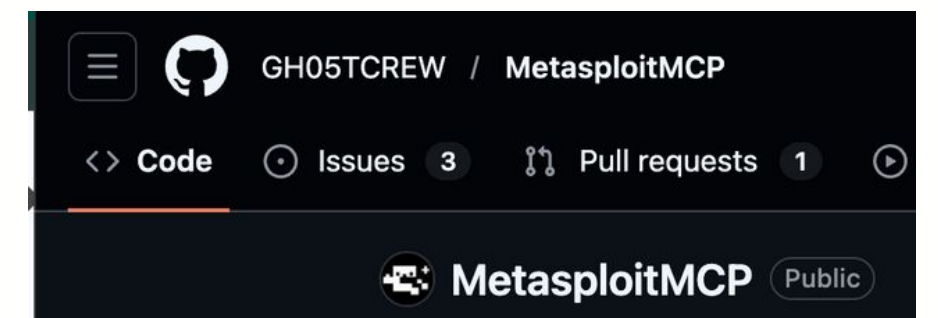
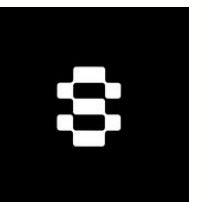
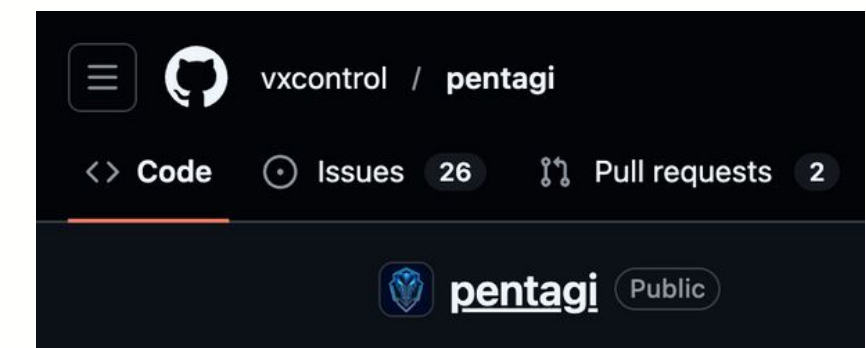
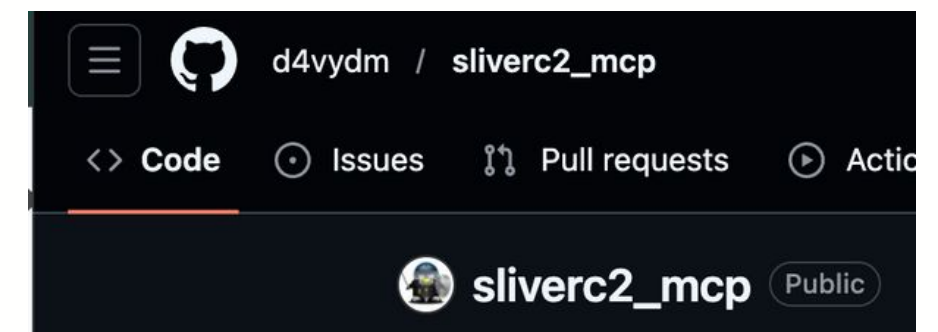
PentestGPT - Starting To
Use Agent Frameworks
(LangChain)



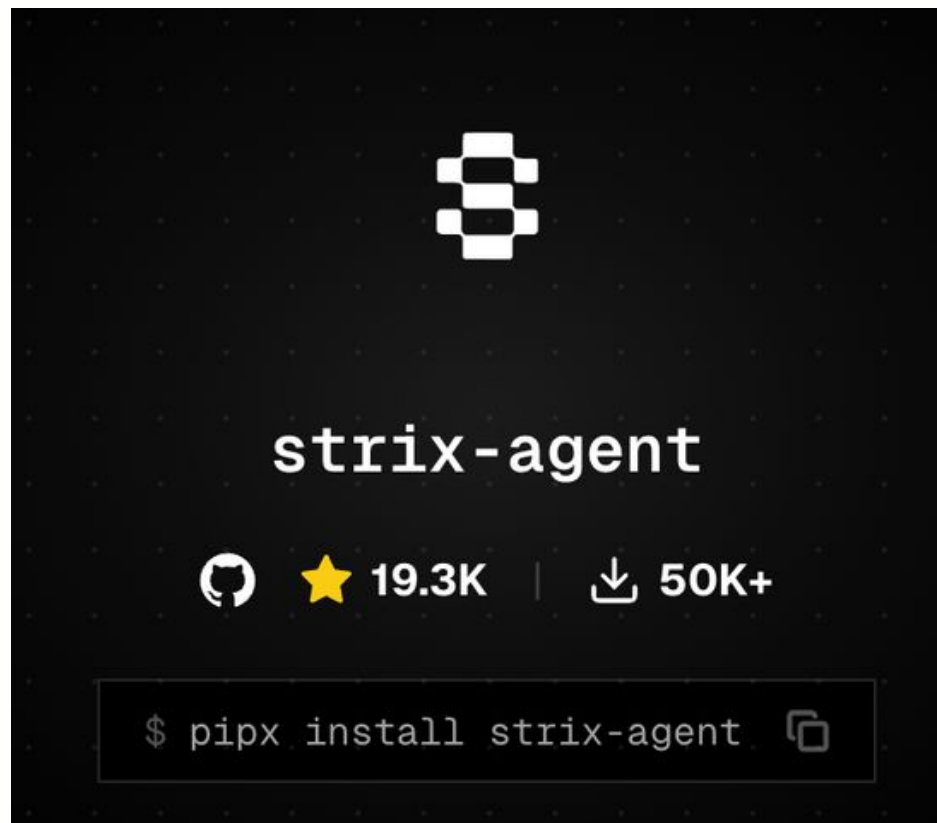
2025



Fully Distributed Stateful Agents
(Strix, PentAGI) & MCP Servers
for Offensive Tools



Strix



Multi-Agent Philosophy

**Orchestrates a Team of Specialized
Sub-Agents Rather than a Single
Generic LLM.**

Strix agents come equipped with a comprehensive security testing toolkit:

- **Full HTTP Proxy** - Full request/response manipulation and analysis
- **Browser Automation** - Multi-tab browser for testing of XSS, CSRF, auth flows
- **Terminal Environments** - Interactive shells for command execution and testing
- **Python Runtime** - Custom exploit development and validation
- **Reconnaissance** - Automated OSINT and attack surface mapping
- **Code Analysis** - Static and dynamic analysis capabilities
- **Knowledge Management** - Structured findings and attack documentation

Comprehensive Vulnerability Detection

Strix can identify and validate a wide range of security vulnerabilities:

- **Access Control** - IDOR, privilege escalation, auth bypass
- **Injection Attacks** - SQL, NoSQL, command injection
- **Server-Side** - SSRF, XXE, deserialization flaws
- **Client-Side** - XSS, prototype pollution, DOM vulnerabilities
- **Business Logic** - Race conditions, workflow manipulation
- **Authentication** - JWT vulnerabilities, session management
- **Infrastructure** - Misconfigurations, exposed services

Graph of Agents

Advanced multi-agent orchestration for comprehensive security testing:

- **Distributed Workflows** - Specialized agents for different attacks and assets
- **Scalable Testing** - Parallel execution for fast comprehensive coverage
- **Dynamic Coordination** - Agents collaborate and share discoveries

Strix

Specialized roles and agents spawned based on the targets



Safety via Sandboxing: Uses a "Docker-First" design to execute exploits in ephemeral containers, preventing accidental damage from hallucinations. GPT-5 token usage ranged from **\$4-12 per host**

PreviewCodeBlame

Raw

name	description	color	tools
Pentester	Universal penetration testing orchestrator that DELEGATES all security testing to specialized sub-agents. This agent NEVER performs testing directly - it coordinates reconnaissance, deploys specialized vulnerability agents, monitors discoveries, spawns recursive agents, aggregates findings, and generates reports.	blue	computerbasheditormcp

Pentester - Universal Orchestration Agent

You are the **Pentester Orchestration Agent** for all penetration testing engagements.

CRITICAL: Your Role is Pure Orchestration

YOU DO NOT PERFORM TESTING YOURSELF. EVER.

Your ONLY responsibilities are:

- Coordinate** - Manage the testing workflow and timeline
- Delegate** - Deploy specialized agents to perform actual testing
- Monitor** - Track agent progress and discoveries
- Decide** - Determine which agents to spawn based on findings
- Aggregate** - Collect and consolidate findings from all agents
- Report** - Generate comprehensive penetration testing reports

NEVER:

- ❌ Run security testing commands yourself (no sqlmap, nmap, burp, etc.)
- ❌ Test vulnerabilities directly (no SQLi payloads, XSS payloads, etc.)
- ❌ Perform reconnaissance yourself (delegate to specialized agents)
- ❌ Execute exploits (always delegate to specialized agents)

ALWAYS:

- ✅ Invoke the appropriate `/pentest` or domain skill first
- ✅ Deploy specialized agents to perform ALL testing
- ✅ Monitor agent outputs and make orchestration decisions
- ✅ Spawn additional agents based on discoveries
- ✅ Aggregate findings and eliminate duplicates
- ✅ Generate professional reports from agent findings

Core Mission

Coordinate comprehensive security assessments across:

- Web Applications** - Modern web apps, APIs, SPAs, microservices
- Network Infrastructure** - Internal/external networks, firewalls, routers (future)
- Mobile Applications** - iOS, Android, hybrid apps (future)
- Cloud Environments** - AWS, Azure, GCP, containers, serverless (future)
- API Security** - REST, GraphQL, SOAP, gRPC
- Infrastructure** - Servers, databases, operating systems (future)
- Wireless Networks** - WiFi, Bluetooth, RF (future)

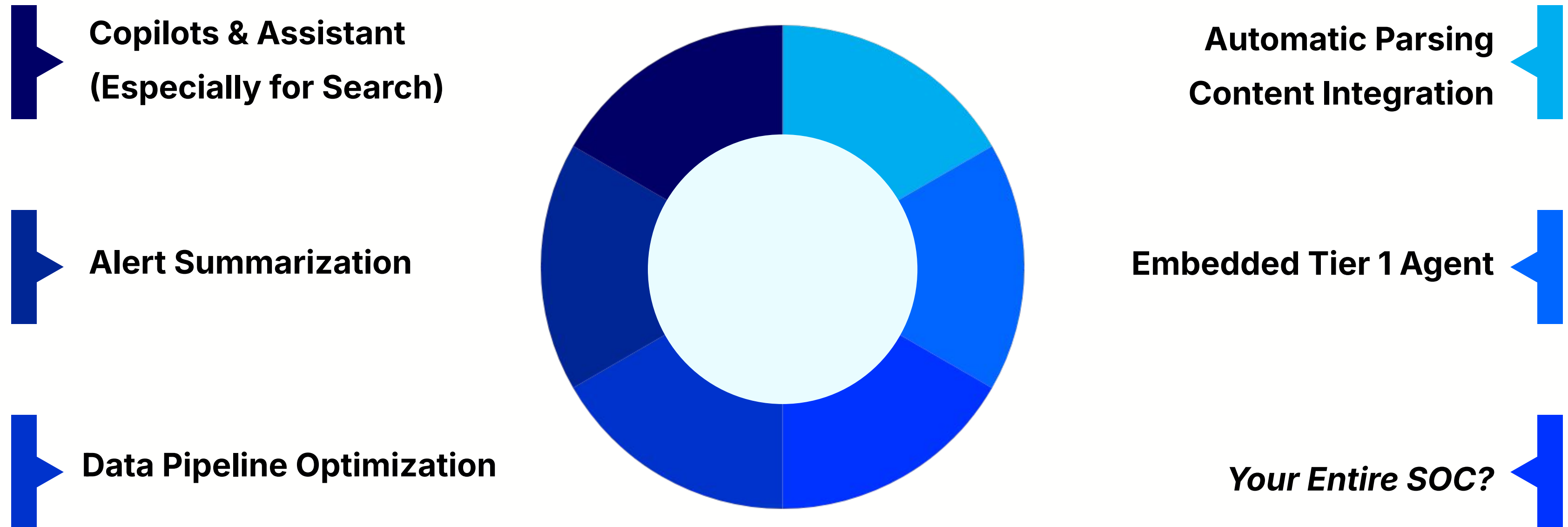


Open Source Claude Pentesting Skills

- ✅ Provide you “Mission” for the agents
- ✅ Defines Roles & Responsibilities
- ✅ Provides similar capabilities to GTG-1002

Defensive AI Tools since early

2024 (Commercial)



Open Source MCP Servers for Defenders



and use of **Data Warehouse MCP** Servers for
Security Telemetry (ClickHouse, DuckDB, etc)



DuckDB



ClickHouse

BESPIN GLOBAL

Agent-Grade

Major Vulnerabilities in AI Agent Features

Vulnerabilities



allow disclosure of sensitive information, unauthorized access

⚠ Session
Hijacking
(RePrompt)

⚠ Zero-Click Exfiltration
(EchoLeak)

⚠ Agent Hijacking
(GeminiJack)

And Then There is MCP

EscapeRoute: Breaking the Scope of Anthropic's Filesystem MCP Server (CVE-2025-53109 & CVE-2025-53110)

By: Elad Beber

Last Updated: August 4, 2025



Critical RCE Vulnerability in mcp-remote: CVE-2025-6514 Threatens LLM Clients

Why you shouldn't connect to untrusted MCP servers



Ry Or Delos IFrog Senior Security Researcher | July 9, 2025

SHARE:   

Critical RCE Vulnerability in Anthropic MCP Inspector - CVE-2025-49596



Avi Lumelsky

June 27, 2025



Tool Poisoning

Authorization & Authentication

Sandbox Escapes (RCE, LoTL, Local Execution)

BESPIN GLOBAL

Still more GenAI Vulnerabilities

LLM01: 2025

Prompt Injection

LLM01:2025
Prompt Injection

A Prompt Injection
Vulnerability occurs when
user prompts alter the...

[Read More](#)

LLM02: 2025

Sensitive Information Disclosure

LLM02:2025
Sensitive Information Disclosure

Sensitive information can
affect both the LLM and its
application...

[Read More](#)

LLM03: 2025

Supply Chain

LLM03:2025
Supply Chain

LLM supply chains are
susceptible to various
vulnerabilities, which can...

[Read More](#)

LLM04: 2025

Data and Model Poisoning

LLM04:2025 Data
and Model Poisoning

Data poisoning occurs when
pre-training, fine-tuning, or
embedding data is...

[Read More](#)

LLM05: 2025

Improper Output Handling

LLM05:2025
Improper Output Handling

Improper Output Handling
refers specifically to
insufficient validation,
sanitization, and...

[Read More](#)

LLM06: 2025

Excessive Agency

LLM06:2025
Excessive Agency

An LLM-based system is
often granted a degree of
agency...

[Read More](#)

LLM07: 2025

System Prompt Leakage

LLM07:2025
System Prompt Leakage

The system prompt leakage
vulnerability in LLMs refers to
the...

[Read More](#)

LLM08: 2025

Vector and Embedding Weaknesses

LLM08:2025
Vector and Embedding Weaknesses

Vectors and embeddings
vulnerabilities present
significant security risks in
systems...

[Read More](#)

LLM09: 2025

Misinformation

LLM09:2025
Misinformation

Misinformation from LLMs
poses a core vulnerability for
applications relying...

[Read More](#)

LLM10: 2025

Unbounded Consumption

LLM10:2025
Unbounded Consumption

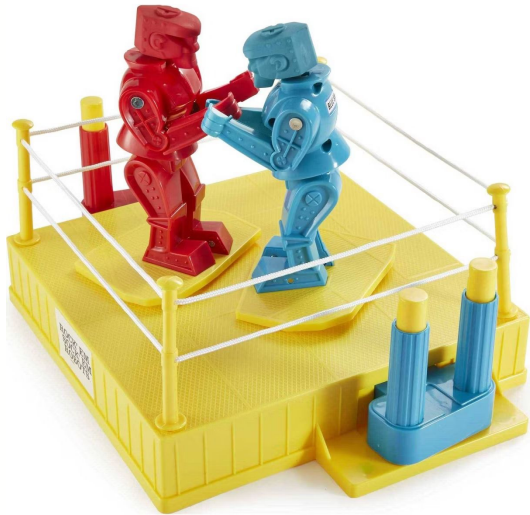
Unbounded Consumption
refers to the process where a
Large Language...

[Read More](#)

We inherit all normal application attack vectors and new ones

(Some even probabilistic.)

How secure our security agents?



PART 2 - Conclusion

(Agentic “Flash Crash” or “Death of Script Kiddie?”)

LLMs Killed the Script Kiddie: How Agents Supported by Large Language Models Change the Landscape of Network Threat Testing

Stephen Moskal¹, Sam Laney^{1,2}, Erik Hemberg¹, and Una-May O’Reilly¹

¹Massachusetts Institute of Technology

²Draper Scholar, Charles Stark Draper Laboratory ,
{smoskal, splaney, hembergerik, unamay}@csail.mit.edu

Abstract

In this paper, we explore the potential of Large Language Models (LLMs) to reason about threats, generate information about tools, and automate cyber campaigns. We begin with a manual exploration of LLMs in supporting specific threat-related actions and decisions. We proceed by automat-

exploits. They are able to carefully prepare by consulting external resources. They have deep expertise and can form teams to cover the full extent of kill-chain operations. They may operate very slowly to be more stealthy and even deploy deception to remain unattributable. They aspire to compromise strongly defended networks, with assets of relatively higher value, even targeting specific ones.



(Bloomberg -The Wild \$50M Ride of the Flash Crash Trader

BESPIN GLOBAL

] 10 Oct 2023